Security Assessment Report

B07 controlled SCA acceptance

Client: Synapse acceptance lab · Generated 2026-10-17 12:27 UTC · Synapse v0.2.5-0.20261017111817-abfa600716bb+dirty

Engagement summary

Client: Synapse acceptance lab

Status: active

Authorization window: 2026-10-17 → 2026-10-17

Report date: 2026-10-17 12:27 UTC

Prepared by Synapse v0.2.5-0.20261017111817-abfa600716bb+dirty – authorized security testing only.

Finding quality

Third-party findings: 7

First-party historical advisories: 0

Dependency confidence: partial

Raw findings: 7

Actionable: 7

Background: 0

Production: 7

Development: 0

Example/Test: 0

Version coverage: 100%

Dependency-path coverage: 0%

Risk priority – P1: 2 P2: 1 P3: 4

Executive summary

This project is at HIGH RISK: 2 critical and 1 high-severity findings require prompt remediation. Required-engine coverage is partial (4/7 completed), so these findings are a lower bound.

Third-party findings: 7

Critical: 2

High: 1

Top remediation priorities

1.	**critical**	CVE-2021-44228 in org.apache.logging.log4j:log4j-core@2.14.1
2.	**critical**	CVE-2021-45046 in org.apache.logging.log4j:log4j-core@2.14.1
3.	**high**	CVE-2021-45105 in org.apache.logging.log4j:log4j-core@2.14.1
4.	**medium**	CVE-2021-44832 in org.apache.logging.log4j:log4j-core@2.14.1
5.	**medium**	CVE-2025-68161 in org.apache.logging.log4j:log4j-core@2.14.1

Scope

in repo /tmp/synapse-b07-private/continuation/sca/controlled-log4j

Authorization window: 2026-10-17 → 2026-10-17

Methodology

Software Composition Analysis: the target was acquired into an isolated workspace (never executed), an SBOM was generated, and components were correlated against vulnerability advisories (OSV + Grype) and de-duplicated per advisory+component+version.

Risk priority orders remediation by CISA KEV first, then EPSS × CVSS – not raw CVSS. Standards: CycloneDX 1.7 + SPDX 3.0, SARIF 2.1, OpenVEX/CSAF, KEV + EPSS. Every artifact is sealed into a per-engagement hash chain.

Third-party findings by severity

critical	2
high	1
medium	4

Detection sources

Findings with advisories: 7

High-confidence (multi-source): 0

Detected by OSV: 7

Detected by Grype: 0

Correlated by both: 0

Third-party findings

SEVERITY	FINDING	STATUS	RISK
critical	CVE-2021-44228 in org.apache.logging.log4j:log4j-core@2.14.1	confirmed	10.00
critical	CVE-2021-45046 in org.apache.logging.log4j:log4j-core@2.14.1	confirmed	9.10
high	CVE-2021-45105 in org.apache.logging.log4j:log4j-core@2.14.1	confirmed	8.60
medium	CVE-2021-44832 in org.apache.logging.log4j:log4j-core@2.14.1	confirmed	6.46
medium	CVE-2025-68161 in org.apache.logging.log4j:log4j-core@2.14.1	confirmed	0.00
medium	CVE-2026-34477 in org.apache.logging.log4j:log4j-core@2.14.1	open	0.00
medium	CVE-2026-34480 in org.apache.logging.log4j:log4j-core@2.14.1	open	0.00

License summary

Coverage: 0% Detected: 0 Unknown: 0

Scan completeness

Required-engine coverage: partial (4/7 completed).

Current execution mode: vulnerabilities.
Unresolved build system(s) present: maven. Their dependencies are NOT fully captured (the transitive tree wasn't resolved from source), so this result is INCOMPLETE – a low finding count does NOT mean clean. For a COMPLETE scan: Maven has no lockfile – scan a BUILT artifact (`mvn package`, then scan the produced JAR or `target/`), or resolve the tree first (`mvn dependency:copy-dependencies -DoutputDirectory=target/deps`) and scan that directory.

ENGINE	EXECUTION	COVERAGE	REASON
code_quality	not_run	not_applicable	not_selected
dependency_resolution	completed	partial	dependency_unresolved
iac	completed	complete	
inventory	completed	complete	
licenses	not_run	not_applicable	not_selected
sast	completed	complete	
sca	completed	partial	unavailable
secret_history	not_run	not_applicable	not_selected
secrets	completed	complete	
taint_go	not_run	not_applicable	not_selected
taint_java	not_run	not_applicable	not_selected
taint_javascript	not_run	not_applicable	not_selected
taint_python	failed	unknown	engine_error

Evidence integrity

VERIFIED – evidence chain intact

Chain head (sha256): f28cf2fc0fa35a58b1fc790ffc1d71bdf8bd74387ff34283e5d07d4a6d223e63

Origin attested (ed25519) by key 11c94778cdbff849 – proves origin, not just integrity.

Reproducibility

Reproducibility score: 57%

Pinned: sbom-generator, epss, correlation, sbom

Live (unpinned): grype-db, kev-catalog, osv.dev

Vuln DB snapshot: osv.dev@2026-10-17T12:27:59Z